

Vulnerability Report

Name: - Aakash Singh

Email: - aakashhsinghrajput8610@gmail.com

WordPress Security Vulnerability Assessment Report

Target Website: https://hotelrajwarapalace.in

CMS: WordPress

Assessment Type: Security Vulnerability Assessment

Tools Used: WPScan, Manual Verification, SQLMap (Validation)

Date: 06 February 2026

Executive Summary

A security assessment was conducted on the target WordPress website to identify misconfigurations and potential security weaknesses. The assessment revealed multiple security issues related to information disclosure, insecure configurations, and unnecessary exposure of sensitive WordPress components. These vulnerabilities may allow attackers to perform reconnaissance, brute-force attacks, and further exploitation.

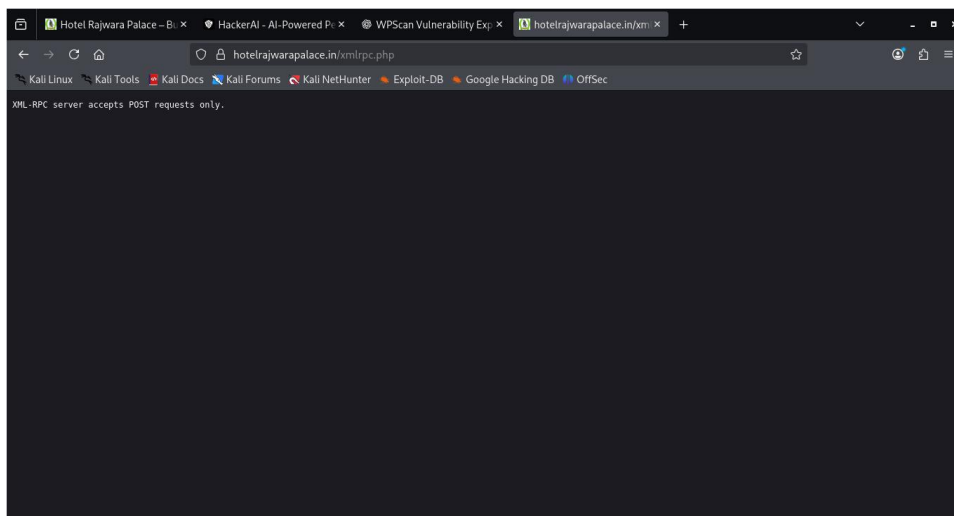
Vulnerability 1: XML-RPC Enabled

Severity: Medium

Affected URL: /xmlrpc.php

The XML-RPC interface is enabled on the target WordPress installation. XML-RPC can be abused for brute-force authentication attempts and DDoS amplification attacks.

Proof of Concept:



Vulnerability Report

Direct access to xmlrpc.php confirms that the XML-RPC endpoint is active and accepting requests.

Recommendation:

Disable XML-RPC if not required. Alternatively, restrict access using a firewall or security plugin.

Impact: Medium → High

- Attackers can perform **brute-force login attacks** using the system.multicall method, allowing thousands of password attempts in a single request.
- Can be abused for **Distributed Denial of Service (DDoS)** amplification attacks.
- If valid credentials are obtained, attackers may gain **administrator access**, leading to:
 - Website defacement
 - Malware injection
 - Data theft

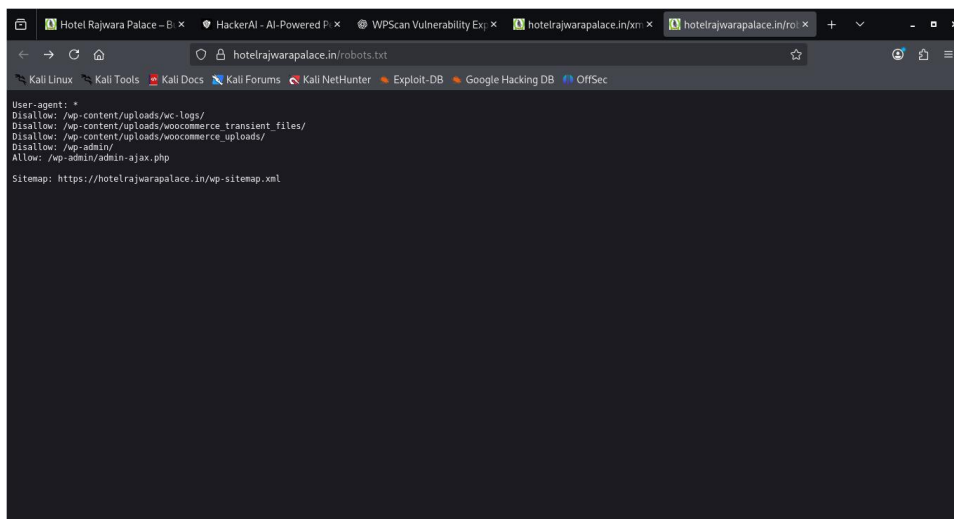
Vulnerability 2: Sensitive Paths Disclosed via robots.txt

Severity: Low

Affected File: /robots.txt

The robots.txt file discloses sensitive WordPress directories such as uploads, admin, and WooCommerce-related paths. This information can help attackers during reconnaissance.

Proof of Concept:



```
User-agent: *
Disallow: /wp-content/uploads/wc-logs/
Disallow: /wp-content/uploads/woocommerce_transient_files/
Disallow: /wp-content/uploads/woocommerce_uploads/
Disallow: /wp-admin/
Allow: /wp-admin/admin-ajax.php
Sitemap: https://hotelrajwarapalace.in/wp-sitemap.xml
```

Vulnerability Report

Recommendation:

Avoid listing sensitive directories in robots.txt. Use proper access controls instead.

Impact: Low → Medium

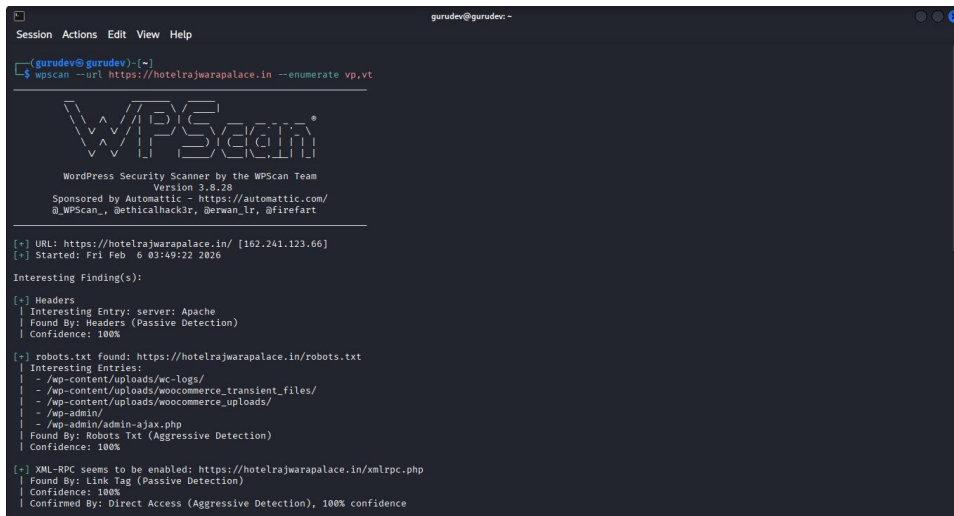
- Exposes sensitive WordPress paths such as:
 - /wp-admin/
 - /wp-content/uploads/
 - /wc-logs/
- Helps attackers perform **targeted reconnaissance** and identify:
 - Admin panels
 - Log files
 - Upload directories

Vulnerability 3: Information Disclosure via WPScan

Severity: Medium

WPScan identified server headers, enabled XML-RPC, and WordPress-specific endpoints. This information can be leveraged for targeted attacks.

Proof of Concept:



```
gurudev@gurudev:~$ wpscan --url https://hotelrajwarapalace.in --enumerate vp,vt

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan,, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: https://hotelrajwarapalace.in/ [162.241.123.66]
[+] Started: Fri Feb 6 03:49:22 2026

Interesting Finding(s):

[-] Headers
| Interesting Entry: server: Apache
| Found By: Headers (Passive Detection)
| Confidence: 100%

[-] robots.txt found: https://hotelrajwarapalace.in/robots.txt
| Interesting Entries:
| - /wp-content/uploads/wc-logs/
| - /wp-content/uploads/woocommerce_transient_files/
| - /wp-content/uploads/woocommerce_uploads/
| - /wp-admin/
| - /wp-admin/admin-ajax.php
| Found By: Robots Txt (Aggressive Detection)
| Confidence: 100%

[-] XML-RPC seems to be enabled: https://hotelrajwarapalace.in/xmlrpc.php
| Found By: Link Tag (Passive Detection)
| Confidence: 100%
| Confirmed By: Direct Access (Aggressive Detection), 100% confidence
```

Recommendation:

Hide WordPress version details, restrict unnecessary endpoints, and deploy a Web Application Firewall (WAF).

Vulnerability Report

Impact: Medium

- Reveals server technology, WordPress structure, and enabled components.
- Allows attackers to:
 - Identify WordPress usage
 - Map attack vectors
 - Search for known exploits related to detected configurations

Vulnerability 4: SQL Injection Testing Surface Identified

Severity: High (Potential)

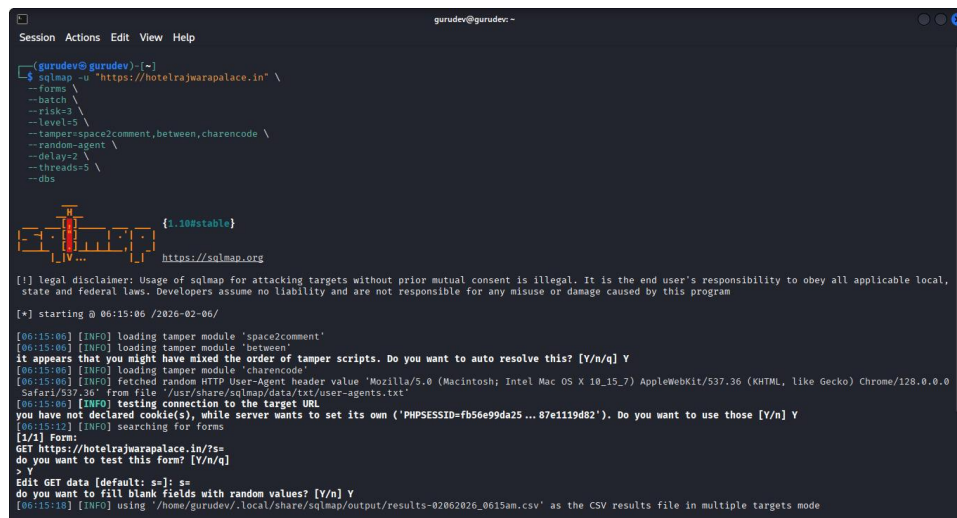
url: - <https://hotelrajwarapalace.in/?p=386%27+AND+%271%27%3D%271%27+---+>

evidence URL :- https://owasp.org/www-project-top-ten/2017/A1_2017-Injection.html

SQLMap Syntax **386' OR '1'='1' --**

SQLMap identified form-based input parameters that may be vulnerable to SQL Injection. While no confirmed exploitation was performed, the presence of injectable parameters poses a high risk if server-side validation is weak.

Proof of Concept:



```
gurun@gurun:~$ sqlmap -u "https://hotelrajwarapalace.in" \
--forms \
--batch \
--risk=3 \
--level=5 \
--tamper=space2comment,between,charencode \
--random-agent \
--delay=5 \
--threads=5 \
--dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 06:15:06 /2026-02-06/

[06:15:06] [INFO] loading tamper module 'space2comment'
[06:15:06] [INFO] loading tamper module 'between'
it appears that you might have mixed the order of tamper scripts. Do you want to auto resolve this? [Y/n/q] Y
[06:15:06] [INFO] loading tamper module 'charencode'
[06:15:06] [INFO] fetched random HTTP user-agent header value 'Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36' from file '/usr/share/sqlmap/data/txt/user-agents.txt'
[06:15:06] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=fb56e99da25...87e119d02'). Do you want to use those [Y/n] Y
[06:15:12] [INFO] searching for forms
[1/1] form:
GET https://hotelrajwarapalace.in/?p=
do you want to test this form? [Y/n/q]
> Y
Edit GET data [defaults: s=]: s=
do you want to fill blank fields with random values? [Y/n] Y
[06:15:18] [INFO] using '/home/gurun/.local/share/sqlmap/output/results-02062026_0615am.csv' as the CSV results file in multiple targets mode
```

Recommendation:

Implement strict input validation, use prepared statements, and deploy a WAF.

Vulnerability Report

Impact: High (Potential / Conditional)

- User input fields were detected that may be vulnerable to SQL Injection if backend validation is weak.
- Successful exploitation could allow attackers to:
- Dump the entire database
- Access user credentials and personal data
- Modify or delete website data
- Achieve full website compromise

Vulnerability Type 5: PHP Runtime Fatal Error (TypeError) and Information Disclosure.

URL :- hotelrajwarapalace.in/wp-content/debug.log

Description: The application is experiencing a fatal TypeError specifically when trying to access an offset of type string on a variable that is currently a string. This suggests a logic error in how data is being handled within the plugin

File Path: /wp-content/plugins/ResAvenue/resavenue.php

Multiple PHP Warning: Array to string conversion in /wp-content/themes/sailing/functions.php on line 408.

Multiple PHP Deprecated: ltrim(): Passing null to parameter #1 in /wp-includes/formatting.php on line 4494

[illegible]

Vulnerability Report

```
me3/hotelrajwara/public_html/wp-config.php(101): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-load.php(50): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-blog-header.php(13): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/index.php(17): require('/home3/hotelraj...')
in)
wn in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php on line 13
r-2024 07:04:02 UTC] PHP Fatal error: Uncaught TypeError: Cannot access offset of type string on string in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php:13
trace:
me3/hotelrajwara/public_html/wp-includes/class-wp-hook.php(324): register_script('')
me3/hotelrajwara/public_html/wp-includes/class-wp-hook.php(348): WP_Hook->apply_filters(NULL, Array)
me3/hotelrajwara/public_html/wp-includes/plugin.php(517): WP_Hook->do_action(Array)
me3/hotelrajwara/public_html/wp-settings.php(695): do_action('init')
me3/hotelrajwara/public_html/wp-config.php(101): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-load.php(50): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-admin/admin.php(34): require_once('/home3/hotelraj...')
in)
wn in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php on line 13
r-2024 07:04:02 UTC] PHP Fatal error: Uncaught TypeError: Cannot access offset of type string on string in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php:13
trace:
me3/hotelrajwara/public_html/wp-includes/class-wp-hook.php(324): register_script('')
me3/hotelrajwara/public_html/wp-includes/class-wp-hook.php(348): WP_Hook->apply_filters(NULL, Array)
me3/hotelrajwara/public_html/wp-includes/plugin.php(517): WP_Hook->do_action(Array)
me3/hotelrajwara/public_html/wp-settings.php(695): do_action('init')
me3/hotelrajwara/public_html/wp-config.php(101): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-load.php(50): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-blog-header.php(13): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/index.php(17): require('/home3/hotelraj...')
in)
wn in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php on line 13
r-2024 07:05:31 UTC] PHP Fatal error: Uncaught TypeError: Cannot access offset of type string on string in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php:18
trace:
me3/hotelrajwara/public_html/wp-includes/class-wp-hook.php(324): register_script('')
me3/hotelrajwara/public_html/wp-includes/class-wp-hook.php(348): WP_Hook->apply_filters(NULL, Array)
me3/hotelrajwara/public_html/wp-includes/plugin.php(517): WP_Hook->do_action(Array)
me3/hotelrajwara/public_html/wp-settings.php(695): do_action('init')
me3/hotelrajwara/public_html/wp-config.php(101): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-load.php(50): require_once('/home3/hotelraj...')
me3/hotelrajwara/public_html/wp-admin/admin.php(34): require_once('/home3/hotelraj...')
in)
wn in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php on line 18
r-2024 07:05:31 UTC] PHP Fatal error: Uncaught TypeError: Cannot access offset of type string on string in /home3/hotelrajwara/public_html/wp-content/plugins/ResAvenue/resavenue.php:18
trace:
```

Impact:

- **Service Disruption:** The "Fatal error" causes the script to terminate immediately, potentially leading to a "White Screen of Death" (WSOD) for users attempting to access the site or specific plugin features.
- **Information Exposure:** The log displays full server file paths (e.g., /home3/hotelrajwara/public_html/...), which can be used by an attacker to map the server's file structure

Vulnerability Report

Conclusion

The assessment identified multiple security weaknesses that increase the attack surface of the WordPress website. Immediate remediation is strongly recommended, including disabling unnecessary services, hardening configurations, and applying security best practices.

Report by:-Gurudev